

First Group Assignment

From risk estimates to a defensible decision

100 marks | Group assignment | Estimated effort: 6–8 hours per student. The deadline, course weight, and group arrangements are those announced on the course page.

Context

Your team advises Cedar Grove Community Services, a fictional nonprofit with an online client portal. A material ransomware/data-extortion incident can interrupt services, require incident response, and trigger additional data-exposure response costs. Management can keep its current controls, add a prevention package, or add a recovery package.

Prevention strengthens access controls; recovery improves restoration and incident response. Their numerical effects are assumptions for this case, not measured product performance. All inputs and calibration records are synthetic. All monetary amounts are Canadian dollars, and the decision horizon is one year.

The decision

Choose the affordable strategy with the lowest expected annual total cost, subject to an annual probability of incident losses above CAD 400,000 of no more than 1%. The annual control budget is CAD 20,000. The two packages cannot be combined within this budget. If none of the permitted options meets the policy, report the conflict instead of silently changing the policy.

Purpose and coding responsibilities

Use the measurement and calibration ideas from Tutorial 1 and the simulation workflow from Tutorial 2 to support a defensible risk assessment. Implement the core loss model, risk metrics, control-selection logic, and dependence test. A precise calculation does not by itself establish reliable real-world assumptions. [1–3]

The notebook supplies imports, CSV loading, argument checks, a lognormal helper, repeated experiment loops, table formatting, and plotting scaffolds. You write the substantive risk-analysis code, not routine file-handling or presentation code. Keep the supplied parameters and tests.

Submission: one notebook only

Submit CMPT318_A1_GroupXX.ipynb, executed and saved with outputs. Put every explanation, displayed calculation, interpretation, and the final 200–250-word management memo in Markdown cells inside the notebook. Do not submit an additional PDF, Pages document, report, CSV, or ZIP. The marker will use the original supplied CSVs.

Aim for no more than 1,100 words of written analysis, including the memo. Tables, equations, and references are excluded. Use NumPy, pandas, Matplotlib, and the standard library. No SciPy, distribution fitting, Bayesian inference, or external data collection is required.

Model and supplied inputs

One simulation trial represents one possible year, with at most one material incident. Costs are non-overlapping. For each strategy, define I as its 0/1 incident indicator; R as incident-response cost in CAD; D as outage duration in days; J as a 0/1 indicator for additional data-exposure response; and C as annual incremental control cost.

$$S = R + c_d D + c_s J, \quad L = IS, \quad T = L + C$$

S is potential loss conditional on an incident, L is annual incident loss, and T is total cost in this model. The daily downtime cost is CAD 30,000 per day; additional response costs CAD 300,000 when $J = 1$. In the baseline, I , R , D , and J are independent, and trials are independent.

The secondary-response probability q is 0.20 conditional on an incident. Its potential-severity indicator is sampled independently of I , so its marginal probability is also 0.20. Part 5 changes only the relationship between D and J . Recovery does not change this marginal probability or the additional-response cost.

Strategy parameters

Current: annual incident probability 0.18; response cost triangular with minimum/mode/maximum CAD 20,000 / 40,000 / 80,000; outage median 4 days and 90th percentile 10 days; annual incremental control cost CAD 0.

Prevention: annual incident probability 0.07; response cost CAD 20,000 / 40,000 / 80,000; outage median 4 days and 90th percentile 10 days; annual control cost CAD 15,000.

Recovery: annual incident probability 0.18; response cost CAD 15,000 / 25,000 / 45,000; outage median 1 day and 90th percentile 2.5 days; annual control cost CAD 15,000.

Use the distribution parameters correctly

The triangular distribution has minimum a , mode m , and maximum b . Its endpoints are hard limits within this model. The lognormal quantiles (the median and 90th percentile) are not hard limits. The supplied helper returns the mean and standard deviation of log duration, using the standard Normal 90th-percentile z value ≈ 1.28155 :

$$\mu = \ln(d_{50}), \quad \sigma = \frac{\ln(d_{90}) - \ln(d_{50})}{z_{0.90}}$$

Separate CSV files, already loaded for you

Keep data/ next to the notebook. `strategy_parameters.csv` contains the three strategies; `calibration_records.csv` contains the ten practice exercises; `case_settings.csv` contains the shared costs, policy settings, and prescribed stress assumptions. The loader and a data dictionary are supplied. Do not create or rewrite these records inside the notebook.

Calibration records use hours and assess estimation practice; the incident-duration model uses days. Do not fit the incident model to the calibration exercises. Control cost is paid even without an incident: include it in total cost, but not in the incident-loss exceedance test.

1. Audit the estimates [15 marks]

1a [4]. Classify the 18% annual incident probability, independence of outage duration and secondary response, and the board's 1% risk limit as an estimate, a modelling assumption, or a policy choice. For the first two, identify specific evidence that could support or challenge the input. Complete the Markdown evidence-audit table.

1b [5]. Complete `calibration_metrics`. For each estimator, calculate inclusive interval coverage, number of misses, and mean width in hours. A hit includes both endpoints. Both estimators claimed 90% intervals before the outcomes were known. The supplied runner builds and displays the two-row summary table.

1c [6]. In 120–160 words, identify results suggesting overconfidence; explain why ten exercises cannot establish calibration and why intervals from 0 to 100 hours are not automatically better. Explain why a 90th percentile is not a hard maximum and why additional simulation trials are not new evidence about control effectiveness.

2. Implement and validate [25 marks]

2a [14]. Complete the analytical body of `simulate_years`: sample the incident indicator, triangular response cost, lognormal outage duration, and secondary indicator; calculate conditional loss and annual incident loss. Follow the documented random-draw order. The generator setup, input checks, and output structure are supplied. Use `secondary_probabilities`; its independent branch is provided and its stress branch belongs to Part 5.

Return the six specified columns: `incident`, `response_cost`, `outage_days`, `secondary`, `conditional_loss`, `annual_loss`. Store potential severity for every row, including no-incident rows, so that the sampler can be checked. Potential costs are not incurred costs: `annual_loss` must equal zero when `incident` equals zero. Exclude control cost from `annual_loss`.

2b [5]. Pass the supplied shape, validity, reproducibility, loss-consistency, and probability-zero/one checks. Add one non-duplicative deterministic risk-model test and a short comment explaining the error it would catch. Keep the given checks. These verify implementation, not realism.

2c [6]. Complete `analytic_eal` using the following benchmark and distribution means:

$$\mathbb{E}[L] = p(\mathbb{E}[R] + c_d \mathbb{E}[D] + qc_s)$$

$$\mathbb{E}[R] = \frac{a + m + b}{3}, \quad \mathbb{E}[D] = \exp\left(\mu + \frac{\sigma^2}{2}\right)$$

The supplied runner uses 100,000 years per strategy, with SEED + i for current, prevention, recovery (i = 0, 1, 2), and displays analytic mean, simulated mean, Monte Carlo standard error, and the difference divided by that error. In 40–60 words, explain one agreement and one limitation. Investigate discrepancies above about four standard errors; do not search for a seed that hides an error.

3. Compare the controls [20 marks]

3a [8]. Complete `loss_summary` and `assess_controls`. Build the decision table for all three strategies: mean annual incident loss, median, 95th and 99th percentiles, $P(L > 400,000)$, control cost, expected annual total cost, net expected benefit, affordability, risk-limit flag, and eligibility. Include zero-loss years in all annual summaries. For strategy k and current controls 0 :

$$\mathbb{E}[T_k] = \mathbb{E}[L_k] + C_k$$

$$\text{NEB}_k = (\mathbb{E}[L_0] + C_0) - (\mathbb{E}[L_k] + C_k)$$

Return the cost-only choice among affordable options and the choice satisfying both budget and risk limit. Return None when the relevant feasible set is empty. The baseline control cost is zero, and its net benefit is zero. Use full precision for calculation and selection, rounding only displays.

3b [6]. Complete `exceedance_probability`. Run the supplied annual-loss exceedance curves (CAD 0-1.2 million), expected total-cost plot, and conditional-severity histogram. Use strict $>$ and all years in the exceedance denominator. Keep the CAD 400,000 and 1% policy markers; an exceedance curve is not a density:

$$\hat{P}(L > x) = \frac{1}{N} \sum_{i=1}^N \mathbf{1}\{L_i > x\}$$

3c [6]. In 120–160 words, compare the cost-only choice with the full-policy choice using numerical results and the curves near the policy threshold. Explain what a zero median does and does not say about risk.

4. Numerical precision is not evidence [15 marks]

4a [8]. Complete `precision_summary`: mean, sample standard deviation ($\text{ddof} = 1$), Monte Carlo standard error, approximate 95% interval for the mean, and P05-P95 annual-loss interval. Report both widths. Run the nine-row table ($N = 1,000, 10,000, 100,000$; three seeds each) and the supplied running-mean stabilization plot.

$$\widehat{\text{SE}}_{\text{MC}} = \frac{s_L}{\sqrt{N}}, \quad \text{CI}_{\text{MC},95\%} \approx \left[\bar{L} - 1.96 \frac{s_L}{\sqrt{N}}, \bar{L} + 1.96 \frac{s_L}{\sqrt{N}} \right]$$

4b [7]. In 100–140 words, explain what stabilizes as N grows, whether either interval width must decrease monotonically in your runs, and the expected standard-error change when N increases 100-fold. Correct the claim: “We simulated 100,000 years, so our input assumptions are now well measured.”

The Monte Carlo interval describes numerical error; P05-P95 describes annual outcomes under the model. Neither validates the inputs. Use the supplied stabilization plot; no additional plotting code is required.

5. Challenge an assumption [25 marks]

A responder suggests that long outages and additional data-exposure response may coincide in more severe incidents. Treat this as a hypothetical stress model, not a newly observed fact and not a claim that downtime causes data exposure.

5a. Preserve the marginals, change the relationship [10]

Complete the stress branch of secondary_probabilities. For each strategy, use the supplied population 90th-percentile duration, not a percentile estimated from your sample:

$$P(J = 1 \mid D > d_{90}) = 0.80$$

$$P(J = 1 \mid D \leq d_{90}) = q_{\text{low}}$$

Derive the lower-duration probability from the law of total probability. The population probability of a duration above that population percentile is 0.10:

$$0.10(0.80) + 0.90q_{\text{low}} = 0.20$$

Show the algebra in the prediction Markdown cell, then implement the conditional probabilities using np.where or equivalent logic. Preserve the individual distributions of R and D, the incident probability, all costs, and the overall probability of J. I remains independent of severity, and R remains independent of D and J.

The provided experiment loop runs 100,000 years for each strategy using the baseline per-strategy seeds. Inspect the long-outage and secondary-response proportions using all potential-severity rows; they should be near 0.10 and 0.20. Review the six-row independent/dependent comparison of EAL, expected total cost, 99th percentile, exceedance probability, and eligibility. Row-wise differences are not measured causal effects.

5b. Predict, then interpret [7]

Before running the stress model, predict whether analytic EAL changes and justify the prediction in 40–60 words. Afterwards, interpret the results in 100–140 words: does the same mean imply the same risk profile; must every percentile or exceedance probability increase; and does any option still meet the policy? Distinguish Monte Carlo fluctuations from changes in analytic expectation.

5c. Management memo, inside the notebook [8]

Write 200–250 words in the final Markdown cell. State the baseline recommendation, what the stress model changes, and any unresolved policy conflict. Refer to at least three numerical results and one relevant textbook idea. Include an important limitation or nonfinancial consideration.

Request one specific measurement: say what would be observed, which assumption it informs, and how it could change or strengthen the decision. Do not claim that a hypothetical stress scenario proves a real control will fail, or that more simulated years validate control effectiveness. Do not create a separate report or PDF.

Assessment and submission guide

What earns credit

Part 1 — 15 marks. Correct calibration calculations and a careful distinction among evidence, estimates, assumptions, and policy. Interpret the small calibration sample cautiously.

Part 2 — 25 marks. Correct loss-generating logic, reproducibility, one meaningful additional risk-model test, analytic expectation, and a defensible interpretation of numerical validation.

Part 3 — 20 marks. Correct annual risk metrics, exceedance calculations, control costs, net benefits, and constrained choice. Interpret the curves and explain the decision, rather than merely producing a table.

Part 4 — 15 marks. Correct numerical-error and annual-outcome calculations, followed by a clear explanation of why computation does not validate model assumptions.

Part 5 — 25 marks. A dependence change that preserves the required marginals, a reasoned prediction and comparison, and a concise evidence-based management memo. Total: 100 marks.

The core analytical code is assessed; the supplied imports, file loading, display formatting, experiment loops, and plotting scaffolds are not separate programming tasks. A table or figure without interpretation is not a complete response. Partial credit is available for a correct method with a local error when the reasoning and limitation are clear.

Before submitting

Restart the kernel and run every cell in order. Resolve errors and unfinished placeholders, then save with outputs visible. Keep the supplied inputs and tests. Do not include large raw tables of simulated years. Use readable figures, explicit units, percentages for probabilities, and full-precision values for decisions.

Submit only CMPT318_A1_GroupXX.ipynb through the course page by the announced deadline. All answers and the final memo remain in Markdown cells. Include group-member contributions and acknowledge sources and assistance according to course policy. The marker will execute the notebook next to the original data/ folder; do not resubmit the CSVs.

Reading and source alignment

[1] CMPT 318. Tutorial 1: Measuring, Calibrating, and Acting on Cyber Risk. Fall 2026 course notebook. Review explicit estimates, calibration, expected annual loss, and current/residual risk.

[2] CMPT 318. From uncertainty to a decision: Monte Carlo cyber-risk analysis. Tutorial Session 2, Fall 2026. Review distribution sampling, quantiles, exceedance, simulation error, and analytic validation.

[3] Hubbard, D. W., and Seiersen, R. How to Measure Anything in Cybersecurity Risk. 2nd edition, Wiley, 2023. Relevant sections: Chapter 2 (measurement as uncertainty reduction), Chapter 3 (Rapid Risk Audit, return on controls, loss-exceedance curves), and Chapter 7 (calibrated estimates).

The book also uses “annualized expected loss.” The case numbers, calibration records, budget rule, and dependence exercise are synthetic teaching material, not empirical findings taken from the textbook. This handout does not create a new collaboration, AI-use, or late-submission policy.

Visual guide: read the plots as in Tutorial 2

The plotting code is supplied. Use these figures to interpret the existing tasks; no separate report, additional plotting implementation, or extra written answer is required.

Before Part 2: Input distributions. Bernoulli bars show probabilities; triangular and lognormal curves show densities. P90 is not a maximum.

Part 3: Annual exceedance and cost. Keep all years in annual-loss probabilities. Expected total cost adds annual control cost to mean incident loss.

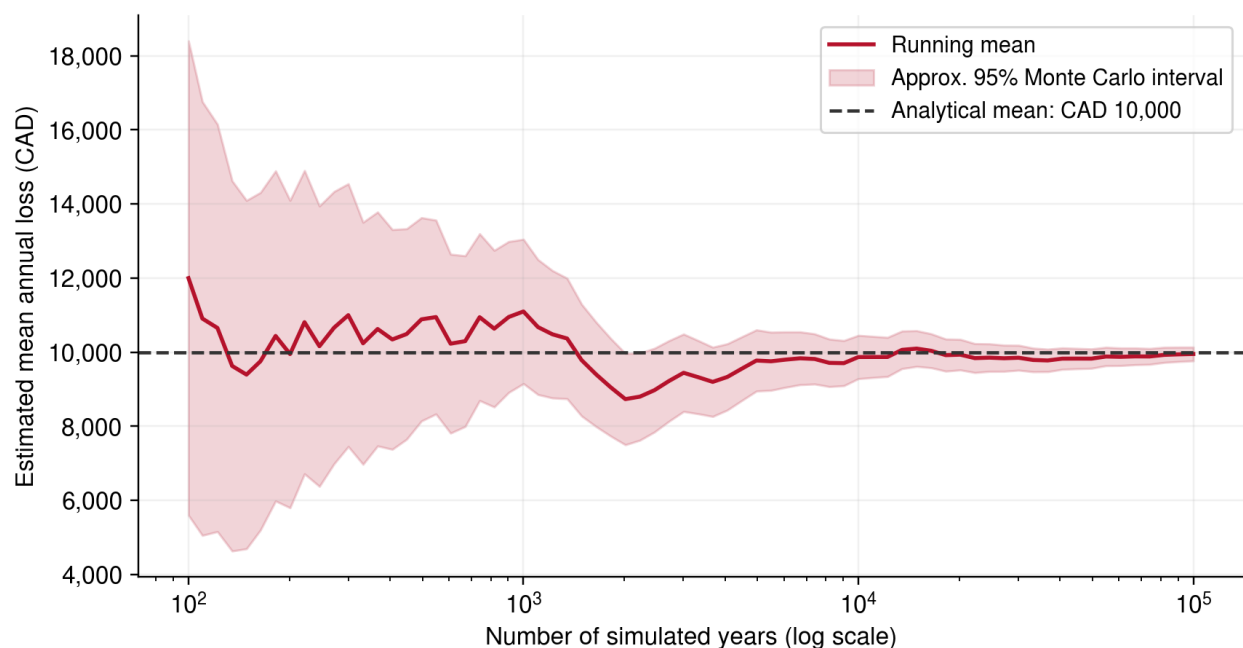
Part 3: Conditional-severity histogram. Inspect the loss distribution in incident years. This figure excludes no-incident years; annual summaries do not.

Part 4: Monte Carlo stabilization. Watch the running mean settle and its numerical uncertainty narrow under the fixed model.

Part 5: Baseline / stress exceedance. Compare each strategy near the CAD 400,000 threshold and 1% annual limit, using the same axes.

A separate stabilization illustration

For illustration only: an incident has probability 10% and a fixed loss of CAD 100,000, giving expected annual loss CAD 10,000. These are not the assignment case inputs.



Line: mean of the first N simulated years. **Band:** approximate 95% Monte Carlo interval for that mean. **Dashed line:** analytical mean under the model. Temporary fluctuations are normal; the band is not a range of possible annual losses.

In your notebook, the same style of plot uses current-controls losses and your completed `precision_summary` function. More trials improve numerical precision without supplying new evidence about control effectiveness.

Short definitions beside the assessed tasks

Calibration and coverage (Part 1). A stated 90% interval should cover the answer about 90% of the time across many comparable estimates. Coverage is the fraction inside; a miss is outside. Interval width is upper minus lower endpoint.

Analytical benchmark and deterministic test (Part 2). The benchmark calculates expectation from model formulas. A deterministic test checks a reproducible relationship with a predictable answer; a random proportion need not equal its population value exactly.

Affordable and eligible (Part 3). Affordable means within the control budget. Eligible, or feasible, means satisfying both the budget and the specified incident-loss risk limit.

Point mass at zero (Parts 3-4). Many annual outcomes are exactly zero because no incident occurs. This is also called zero inflation. Percentile intervals need not contain exactly the stated fraction when a boundary has a point mass.

Sample SD, ddof=1, and monotonic change (Part 4). Sample standard deviation describes spread. ddof=1 uses N-1 in the variance denominator. Monotonically decreasing means smaller at every successive step, without an upward fluctuation.

Conditional probability (Part 5). $P(J=1 \mid D>d90)$ is the probability of additional response within the long-outage group. The vertical bar means given that.

Marginals and dependence (Part 5). A marginal is one variable's overall probability or distribution, considered on its own. Dependence means knowing one variable changes probabilities for another; it does not establish causation.

Law of total probability (Part 5). Overall probability is a weighted average of subgroup probabilities: w times q_{high} plus $(1-w)$ times q_{low} .

Population and sample percentiles (Part 5). A population percentile belongs to the specified distribution. A sample percentile is estimated from finite draws and fluctuates. Use the supplied population d90 in the stress rule.

Linearity of expectation (Part 5). $E[A+B] = E[A] + E[B]$, including when A and B are dependent. How their outcomes occur together can still change the distribution of the sum.

Separate probability example: 25% of devices are in a group with fault probability 10%; the other 75% have fault probability 2%. The overall probability is $0.25(0.10) + 0.75(0.02) = 0.04$, or 4%. Apply the weighting idea to the assignment's own stress rule.